

Cybersecurity capability model

Version 1 · Detailed L1 and L2 capability reference

01

Govern, risk & assure

11 capabilities

02

Protect & defend

22 capabilities

03

Identity & data

8 capabilities

How to read this pack

Structure

Three tiers organise the model:

- Tier 1 — Govern, risk & assure
- Tier 2 — Protect & defend
- Tier 3 — Identity & data

Each tier contains L1 capabilities. Each L1 capability is decomposed into 4 L2 sub-capabilities with descriptions to support assessment, scoping and design conversations.

Use cases

- Capability assessments — score each capability on a 1-5 maturity scale
- Gap analysis against ISO 27001:2022, NIST CSF 2.0, POPIA and PCI DSS 4.0
- Target operating model and roadmap design
- Investment prioritisation and budget articulation
- Audit preparation and regulator engagement
- Engagement scoping and proposal development

Standards alignment

ISO/IEC 27001:2022 · ISO/IEC 27002:2022 · ISO/IEC 27701 · ISO/IEC 42001 · NIST CSF 2.0 · NIST AI RMF · NIST PQC (FIPS 203/204/205) · CIS Controls v8.1 · PCI DSS 4.0 · POPIA · GDPR · SARB Joint Standard 2 of 2024 · King IV

A modern security capability framework

3 tiers · 33 capabilities · audit-defensible · future-aligned

33

capabilities

01 Govern, risk & assure 11 capabilities	Strategy & program Vision, roadmap, board reporting		Risk management Cyber risk register, FAIR quantification		Compliance Privacy, ISO, PCI, sector regulations		Audit & assurance Internal audit, control testing									
	AI governance NIST AI RMF, ISO 42001, model risk		Privacy program DPIAs, consent, cross-border transfers		3rd party & supply chain Vendor risk, SBOM policy, concentration		Cyber insurance Policy strategy, evidence, claims									
	Human risk & awareness Phishing sim, culture, behaviour analytics		Policies & standards Policy framework, exception management		Metrics & reporting KRIs, KPIs, board dashboards											
02 Protect & defend 22 capabilities	Zero trust architecture ZTNA, microsegmentation, policy engine		Cloud security CNAPP, CSPM, CWPP, CIEM, SSPM		Endpoint & mobile EDR, MDM, MTD, hardening, patching		Network & perimeter SASE, SWG, email, DDoS, DNS		Wireless security Wi-Fi, guest segregation, rogue AP		App & product security DevSecOps, SAST/DAST, SCA, API security					
	Configuration & hardening CIS, STIGs, baselines, drift, IaC		Vulnerability mgmt CTEM, attack surface, pen test		Software supply chain ops SBOM, SLSA, build integrity, signing		Cryptographic operations Crypto inventory, PKI, PQC migration		Detection & response SIEM, XDR, SOAR, threat hunting, MDR		Threat intelligence CTI, deception, brand protection					
	Fraud & transactional Real-time monitoring, FICA, AML		Forensics & DFIR Evidence handling, insider threat		Agentic AI security ops AI triage, agent governance, oversight		Logging & telemetry Source coverage, retention, integrity		Cyber resilience Immutable backups, IR plan, tabletops		Service continuity BCM, DR, RTO/RPO, crisis management					
	Availability & capacity Performance, capacity, exhaustion defence		OT / IoT / smart bldg Asset visibility, IT/OT segmentation		Physical & environmental Facility access, CCTV, secure disposal		Asset management CMDB, HW/SW inventory, shadow IT									
03 Identity & data 8 capabilities	Workforce identity SSO, MFA, IGA, PAM, ITDR				Customer identity (CIAM) Auth, fraud, consent, passwordless				Non-human identity Service accounts, secrets, API keys				Data discovery & posture DSPM, classification, lineage			
	Data protection DLP, encryption, masking, tokenisation				AI & data trust Shadow AI, prompt & model security				Records & data lifecycle Retention, legal hold, secure disposal				Data subject rights DSAR processing, complaints, regulator			

Govern, risk & assure

Strategy, oversight, accountability — 11 capabilities

The governance tier sets direction, allocates accountability, manages risk and demonstrates compliance. This is where the security programme integrates with enterprise risk, board oversight, regulators and insurers.

Strategy & program	Risk management	Compliance	Audit & assurance	AI governance	Privacy program
3rd party & supply chain	Cyber insurance	Human risk & awareness	Policies & standards	Metrics & reporting	

Strategy & program

L2 sub-capabilities

L2 sub-capability	Description
Vision & strategy	Multi-year security vision aligned to enterprise strategy and risk appetite.
Programme roadmap	Prioritised initiatives, dependencies, investment plans and delivery milestones.
Operating model	Centralised, federated or hybrid security operating model with clear RACI.
Board reporting	Cadence, format and content of board and executive committee reporting.

Risk management

L2 sub-capabilities

L2 sub-capability	Description
Cyber risk register	Identification, assessment, treatment and tracking of cyber risks.
Risk appetite & tolerance	Quantified statements defining acceptable risk by category.
Risk quantification	FAIR or equivalent quantification translating risk into financial terms.
Threat & scenario analysis	Structured analysis of plausible attack scenarios and impact.

Compliance

L2 sub-capabilities

L2 sub-capability	Description
Regulatory mapping	Inventory of applicable laws, regulations and contractual obligations.
Control framework	Mapping to ISO 27001, NIST CSF, PCI DSS, Privacy and sector requirements.
Compliance monitoring	Ongoing monitoring of control effectiveness and obligation status.
Regulatory reporting	Defined process for breach, incident and supervisory reporting.

Audit & assurance

L2 sub-capabilities

L2 sub-capability	Description
Internal audit liaison	Coordinated planning, evidence collection and remediation tracking.
External audit support	Support for ISO, SOC, PCI and regulator-led assessments.
Control testing	Independent testing of design and operating effectiveness.
Continuous controls monitoring	Automated, continuous evidence collection and control validation.

AI governance

L2 sub-capabilities

L2 sub-capability	Description
AI policy & standards	Acceptable use, prohibited use cases, approval gates and controls.
AI risk management	Model risk assessment, bias testing, explainability and oversight.
AI inventory & BoM	Centralised inventory of AI systems, models, data and dependencies.
Regulatory alignment	Alignment to NIST AI RMF, ISO 42001, EU AI Act and SA guidance.

Privacy program

L2 sub-capabilities

L2 sub-capability	Description
Privacy governance	Information Officer, privacy committee and accountability structure.
DPIAs & PIAs	Privacy impact assessments for new processing, products and vendors.
Consent management	Lawful basis, consent capture, withdrawal and preference management.
Cross-border transfers	Adequacy, contracts and safeguards for international data flows.

3rd party & supply chain

L2 sub-capabilities

L2 sub-capability	Description
Vendor risk management	Tiering, due diligence, ongoing monitoring and exit planning.
SaaS posture (governance)	Inventory, risk classification and policy for SaaS adoption.
SBOM & software risk	Policy and oversight for software bill of materials across the estate.
Concentration risk	Identification and management of cloud, vendor and platform concentration.

Cyber insurance

L2 sub-capabilities

L2 sub-capability	Description
Policy strategy	Coverage strategy, limits, sub-limits and exclusion analysis.
Underwriter evidence	Control attestations, evidence packs and renewal preparation.
Claims management	Notification process, panel coordination and claims execution.
Insurance-grade controls	Mapping insurer-required controls to internal control library.

Human risk & awareness

L2 sub-capabilities

L2 sub-capability	Description
Security culture programme	Multi-year programme to embed security into culture and behaviour.
Phishing simulation	Realistic phishing campaigns with measurement and targeted intervention.
Role-based training	Tailored training for high-risk roles, developers and executives.
Behaviour analytics	Quantified human risk scoring and targeted remediation.

Policies & standards

L2 sub-capabilities

L2 sub-capability	Description
Policy framework	Policy hierarchy, ownership, approval and lifecycle management.
Standards lifecycle	Definition, maintenance and retirement of technical standards.
Exception management	Risk-based exception process with expiry and compensating controls.
Policy awareness	Communication, attestation and tracking of policy acknowledgement.

Metrics & reporting

L2 sub-capabilities

L2 sub-capability	Description
KRIs & KPIs	Defined risk and performance indicators with thresholds.
Executive dashboards	Curated dashboards for CISO, ExCo and board audiences.
Regulator reporting	Defined formats and cadence for regulatory submissions.
Benchmarking	Internal trend analysis and external peer benchmarking.

Protect & defend

Architecture, controls, detection, response, recovery — 22 capabilities

The operational tier where security is delivered. Capabilities span architecture, preventative controls, detection, response and recovery, and the foundational operational disciplines that underpin all of them.

Zero trust architecture	Cloud security	Endpoint & mobile	Network & perimeter	Wireless security	App & product security
Configuration & hardening	Vulnerability management	Software supply chain ops	Cryptographic operations	Detection & response	Threat intelligence
Fraud & transactional	Forensics & DFIR	Agentic AI security ops	Logging & telemetry	Cyber resilience	Service continuity
Availability & capacity	OT / IoT / smart bldg	Physical & environmental	Asset management		

Zero trust architecture

L2 sub-capabilities

L2 sub-capability	Description
ZTNA	Identity-aware, context-based access to applications replacing legacy VPN.
Microsegmentation	Workload-level segmentation reducing lateral movement.
Policy decision & enforcement	Centralised policy engine with distributed enforcement points.
Continuous verification	Ongoing trust evaluation based on device, user and behaviour signals.

Cloud security

L2 sub-capabilities

L2 sub-capability	Description
CSPM	Cloud security posture management for misconfiguration detection.
CWPP	Cloud workload protection for VMs, containers and serverless.
CIEM	Cloud infrastructure entitlement management for cloud permissions.
SaaS security posture (SSPM)	Configuration and risk monitoring across SaaS applications.

Endpoint & mobile

L2 sub-capabilities

L2 sub-capability	Description
EDR / XDR endpoint	Behavioural detection, response and forensics on endpoints.
Mobile device management	MDM, MAM and mobile threat defence for managed devices.
Endpoint hardening	Baseline hardening, application control and privilege management.
Patch & update management	Timely patching across operating systems and applications.

Network & perimeter

L2 sub-capabilities

L2 sub-capability	Description
SASE / SSE	Converged secure access service edge with SWG, CASB and FWaaS.
Email security	Anti-phishing, anti-spoofing, BEC protection and DMARC enforcement.
DNS & web filtering	Protective DNS, URL filtering and threat intelligence integration.
DDoS protection	Volumetric and application-layer DDoS mitigation.

Wireless security

L2 sub-capabilities

L2 sub-capability	Description
Corporate Wi-Fi	WPA3, certificate-based authentication and segmentation.
Guest network	Isolated guest access with content filtering and bandwidth control.
Rogue AP detection	Wireless intrusion detection and rogue access point response.
IoT-on-Wi-Fi	Dedicated IoT SSIDs with restricted segmentation.

App & product security

L2 sub-capabilities

L2 sub-capability	Description
DevSecOps	Security integrated into CI/CD pipelines and developer workflows.
SAST / DAST / IAST	Static, dynamic and interactive application security testing.
SCA	Software composition analysis for open source dependencies.
API security	API discovery, schema validation, abuse detection and rate limiting.

Configuration & hardening

L2 sub-capabilities

L2 sub-capability	Description
Secure baselines	CIS Benchmarks, DISA STIGs or equivalent baseline definitions.
Drift detection	Detection of configuration drift from approved baselines.
Golden images	Hardened, versioned base images for consistent deployment.
IaC security	Infrastructure-as-code scanning and policy-as-code enforcement.

Vulnerability management

L2 sub-capabilities

L2 sub-capability	Description
Vulnerability scanning	Authenticated scanning across infrastructure, apps and cloud.
CTEM	Continuous threat exposure management — prioritised, threat-informed.
Attack surface management	External attack surface discovery and monitoring.
Penetration & red teaming	Targeted testing and adversary simulation.

Software supply chain ops

L2 sub-capabilities

L2 sub-capability	Description
SBOM management	Generation, storage and querying of SBOMs across the portfolio.
Build pipeline integrity	SLSA-aligned controls protecting build environments and artifacts.
Dependency scanning ops	Continuous scanning of dependencies for vulnerabilities and malicious packages.
Artifact signing	Cryptographic signing and verification of software artifacts.

Cryptographic operations

L2 sub-capabilities

L2 sub-capability	Description
Cryptographic inventory	Discovery and inventory of cryptography across applications and infrastructure.
PKI & certificate ops	Certificate lifecycle management, root trust and revocation.
Key & secrets management	KMS, HSM and secrets vaults with rotation and access governance.
Post-quantum migration	Crypto-agility programme and migration to PQC standards.

Detection & response

L2 sub-capabilities

L2 sub-capability	Description
SIEM & log analytics	Centralised log aggregation, correlation and investigation.
XDR / SOAR	Extended detection and orchestrated response across telemetry sources.
Threat hunting	Proactive, hypothesis-driven hunting for undetected threats.
MDR / managed detection	External or co-managed 24x7 detection and response capability.

Threat intelligence

L2 sub-capabilities

L2 sub-capability	Description
Strategic CTI	Adversary tracking, geopolitical context and executive briefings.
Tactical & technical CTI	IOCs, TTPs and detection content shared with operations.
Brand & exec protection	External monitoring for brand abuse and executive impersonation.
Deception technology	Honeypots, honey tokens and decoy assets for early detection.

Fraud & transactional

L2 sub-capabilities

L2 sub-capability	Description
Real-time monitoring	Transaction-level fraud detection and prevention.
Fraud rules & ML models	Rule-based and machine learning detection models.
FICA & AML alignment	Integration with regulatory financial crime obligations.
Fraud case management	Investigation workflow, recovery and reporting.

Forensics & DFIR

L2 sub-capabilities

L2 sub-capability	Description
Digital forensics	Acquisition, preservation and analysis of digital evidence.
Incident response	Defined IR playbooks, retainers and command structure.
Insider threat	Detection and investigation of insider risk and misuse.
Evidence handling	Chain of custody, legal admissibility and litigation support.

Agentic AI security ops

L2 sub-capabilities

L2 sub-capability	Description
AI-assisted triage	Use of AI agents for alert enrichment and triage.
Autonomous response	Bounded autonomous actions for well-defined response scenarios.
Agent governance	Oversight, guardrails and audit trails for AI agents in security ops.
Human-in-the-loop	Defined human approval points for high-impact actions.

Logging & telemetry

L2 sub-capabilities

L2 sub-capability	Description
Source coverage	Defined logging requirements across infrastructure, apps and cloud.
Retention & archival	Tiered retention aligned to investigation, audit and legal needs.
Pipeline integrity	Tamper-evident, reliable telemetry pipelines and quality monitoring.
Cost & scale	Telemetry routing, sampling and cost optimisation.

Cyber resilience

L2 sub-capabilities

L2 sub-capability	Description
Immutable backups	Air-gapped, immutable backups for ransomware recovery.
Recovery testing	Regular, realistic testing of recovery time and integrity.
Incident response plan	Documented, tested cyber incident response plan.
Tabletop exercises	Executive and technical tabletop exercises with measurable outcomes.

Service continuity

L2 sub-capabilities

L2 sub-capability	Description
Business continuity	BIA-driven continuity plans for critical business processes.
Disaster recovery	Defined RTO and RPO per service with tested DR procedures.
Crisis management	Crisis command structure, communications and decision authority.
Third-party continuity	Continuity arrangements and exit plans for critical suppliers.

Availability & capacity

L2 sub-capabilities

L2 sub-capability	Description
Performance monitoring	Availability and performance monitoring for security-relevant services.
Capacity planning	Forward-looking capacity for security infrastructure and telemetry.
Resource exhaustion defence	Protection against resource exhaustion attacks.
Service health reporting	Service-level reporting for security platforms and shared services.

OT / IoT / smart bldg

L2 sub-capabilities

L2 sub-capability	Description
OT asset visibility	Discovery and inventory of operational technology assets.
IT/OT segmentation	Network segmentation and conduit controls between IT and OT.
Smart building security	Security for BMS, access control, CCTV and other building systems.
IoT lifecycle	Onboarding, monitoring and decommissioning of IoT devices.

Physical & environmental

L2 sub-capabilities

L2 sub-capability	Description
Facility access control	Access control, visitor management and tailgating prevention.
Environmental controls	Fire suppression, power, cooling and physical resilience.
Clean desk & secure print	Workplace controls for paper, screens and removable media.
Secure disposal	Secure destruction of media, hardware and physical records.

Asset management

L2 sub-capabilities

L2 sub-capability	Description
Hardware inventory	Authoritative inventory of all hardware assets.
Software inventory	Authoritative inventory of installed software and versions.
Shadow IT discovery	Discovery of unsanctioned applications and services.
Lifecycle management	Lifecycle from procurement through decommissioning and EoL.

Identity & data — the new perimeters

Centred on what matters most: who, and what — 8 capabilities

Identity and data are the modern perimeters. This tier elevates them to first-class citizens with their own architectural and operational disciplines, recognising that traditional network boundaries no longer define security boundaries.

Workforce identity	Customer identity (CIAM)	Non-human identity	Data discovery & posture
Data protection	AI & data trust	Records & data lifecycle	Data subject rights

Workforce identity

L2 sub-capabilities

L2 sub-capability	Description
SSO & MFA	Single sign-on with phishing-resistant multi-factor authentication.
Identity governance (IGA)	Joiner-mover-leaver, access reviews and certifications.
Privileged access (PAM)	Vaulting, just-in-time access and session monitoring for privileged accounts.
Identity threat detection (ITDR)	Detection of identity-based attacks and anomalous behaviour.

Customer identity (CIAM)

L2 sub-capabilities

L2 sub-capability	Description
Customer authentication	Risk-based, passwordless and biometric authentication for customers.
Fraud & abuse detection	Account takeover, bot and fraud detection at authentication.
Consent & preferences	Privacy-aligned consent capture and preference management.
Federated & social login	Federation, social login and verifiable credentials integration.

Non-human identity

L2 sub-capabilities

L2 sub-capability	Description
Service account governance	Inventory, ownership, rotation and decommissioning of service accounts.
Secrets management	Centralised secrets vault with rotation and least-privilege access.
API key & token lifecycle	Lifecycle management for API keys, tokens and certificates.
Workload identity	Workload identity federation and short-lived credentials.

Data discovery & posture

L2 sub-capabilities

L2 sub-capability	Description
Data discovery & classification	Automated discovery and classification across data stores.
DSPM	Data security posture management across cloud and SaaS.
Data lineage	Visibility of data flow from source to consumption.
Ownership & stewardship	Defined data owners, stewards and accountability.

Data protection

L2 sub-capabilities

L2 sub-capability	Description
DLP	Data loss prevention across endpoint, network, email and cloud.
Encryption at rest & in transit	Pervasive encryption with appropriate key management.
Tokenisation & masking	Tokenisation and dynamic masking for sensitive data.
Rights management (IRM)	Persistent protection following data outside the perimeter.

AI & data trust

L2 sub-capabilities

L2 sub-capability	Description
Shadow AI discovery	Discovery and inventory of unsanctioned AI usage.
Prompt & input security	Defence against prompt injection and adversarial inputs.
Model security	Protection against model theft, evasion and poisoning.
AI data governance	Controls on training data, fine-tuning data and RAG inputs.

Records & data lifecycle

L2 sub-capabilities

L2 sub-capability	Description
Retention schedules	Defined retention by record class with regulatory alignment.
Legal hold	Process for placing and releasing legal holds on data.
Secure disposal	Verifiable disposal of data at end of retention.
Archival	Long-term archival with integrity, accessibility and cost optimisation.

Data subject rights

L2 sub-capabilities

L2 sub-capability	Description
DSAR processing	Workflow for handling data subject access requests within statutory timeframes.
Consent management ops	Operational management of consent state across systems.
Complaints handling	Process for receiving, investigating and resolving privacy complaints.
Regulator liaison	Defined liaison with the Information Regulator and other authorities.

Apply this model

From framework to outcome

01

Capability assessment

Score current and target maturity per L1 capability with weighted gap analysis.

02

Roadmap & investment plan

Prioritised, sequenced initiatives with cost, effort and dependency analysis.

03

Target operating model

RACI, headcount, organisation design and sourcing strategy aligned to the model.